

-

File No.: EXP202400080

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On January 23, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against CAJA RURAL DE ZAMORA COOPERATIVA DE CRÉDITO (hereinafter the claimed party). After notifying the initiation agreement and analyzing the allegations presented, on December 3, 2024, the proposed resolution was issued, which is transcribed below:

<<

File No.: EXP202400080

PROPOSED RESOLUTION OF SANCTIONING PROCEDURE

From the procedure initiated by the Spanish Agency for Data Protection and based on the following:

BACKGROUND

FIRST: On 01/11/2023, a security breach of personal data of the entity belonging to the GRUPO CAJA RURAL: CAJA RURAL DE ZAMORA with NIF (...) (hereinafter CAJAZAMORA or the entity) was notified as the data controller. It should be noted that, as a result of notifications to the Division of Technological Innovation of this Agency regarding the personal data breach in various Entities of the aforementioned Group, including the claimed party, related to a cyber-incident, the General Subdirectorate of Data Inspection was ordered to carry out the appropriate preliminary investigations to determine a possible violation of data protection regulations.

1. Initially, the breach notifications were made by the data processor RURAL SERVICIOS

INFORMÁTICOS S.L. (hereinafter RSI), concerning 19 entities of the Group:

2. The initial notification date and additional notification date are: 12/12/2022 and 10/01/2023.

3. However, on 13/12/2022, 14/12/2022, and 15/12/2022, breach notifications were made by another 7 entities of the group, located at C/ Jorge Juan, 6, 28001 – Madrid, in their capacity as data controllers, despite the fact that the data processor is the same.

The breach notification forms are accompanied by the Security Incident Report prepared in all cases by RSI, the data processor.

- Date of breach detection: 09/12/2022

- Date of breach occurrence: 10/11/2023

- Summary of the notification:

(...)

- Type of affected data:

Basic data (name, surname, date of birth), DNI, NIE, Passport and/or (...)

- Approximate number of individuals whose personal data is collected, stored, or otherwise processed exclusively regarding the processing in which the breach occurred, No. of individuals (...)

- Approximate number of individuals whose data has been affected by the breach, (...)

- No. communicated (...)

SECOND: As a result of the notifications to the Division of Technological Innovation of this Agency regarding the personal data breach in various Entities of the GRUPO CAJA RURAL related to a cyber-incident, the General Subdirectorate of Data Inspection is ordered to carry out the appropriate preliminary investigations to determine a possible violation of data protection regulations.

During these proceedings, the following Entities have been investigated:

CAJAZAMORA with NIF (...) located at AVENIDA DE (...) 49013 ZAMORA.

And 25 more entities belonging to the GRUPO CAJA RURAL, as well as RSI in its capacity as data processor.

In order to investigate the occurrence of the described facts, on 29/03/2023, a request for information was made to RSI. The response to the request was received on 14/04/2023.

On 12/05/2023 and 27/09/2023, RSI was requested to expand the information provided, and on

26/05/2023 and 11/10/2023, responses were received at the electronic headquarters of the AEPD.

In order to introduce the applications involved in the breach that will be referenced throughout this report, the description included in the documentation provided by RSI in the context of the investigation proceedings is reproduced below:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/58

In order to investigate the occurrence of the described events, on 29/03/2023, a request for information was made to RSI. The response to the request was received at the electronic headquarters of the AEPD on 14/04/2023. On 12/05/2023 and 27/09/2023, additional information was requested from RSI, and responses were received at the electronic headquarters of the AEPD on 26/05/2023 and 11/10/2023, respectively.

In order to introduce the applications involved in the breach that will be referenced throughout this report, the description provided in the documentation submitted by RSI as part of the investigation proceedings is reproduced below:

(...)

Furthermore, RSI, in its document received at the AEPD on 14/04/2023, states:

(...)

Regarding the number of users served by Electronic Banking and the modes of access:

(...)

Regarding the chronology of the events. Actions taken to minimize adverse effects and measures adopted for final resolution

In the Security Incident Analysis Report accompanying the breach notification form, it is stated:

(...)

From the areas of RSI responsible for fraud and the development of the NBE, an investigation was initiated to understand how the fraud occurred.

(...)

1. The mitigating measures taken on December 7 and 9 were:

(...)

Regarding the causes that made the breach possible

- Contributing factors that led to the incident

(...)

Regarding the affected data

The information that may have been accessed during the breach includes personal, contact, and financial data:

(...)

In the Security Incident Analysis Report accompanying the breach notification form, the type of information extracted by the cybercriminal and the impact on individual clients is analyzed, taking into account, among others, the following variables:

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/58

During the course of the investigation proceedings, additional information was requested from RSI regarding the data of clients who do not have an Electronic Banking Agreement that the users involved in the breach may have accessed. In its response, RSI states that:

(...)

Regarding the data processing agreement

RSI provides the Register of Processing Activities of RSI and indicates that the processing related to

Electronic Banking operations is the Client Management processing, where RSI acts as the processor. RSI provides the Agreement modifying the data protection clause of the service provision contracts signed between CAJA RURAL DE JAÉN, BARCELONA Y MADRID, S.C.C. (data controller), and RSI (data processor).

RSI indicates that this Agreement was signed with the Entities in 2018 and that it is the same model for all of them.

The Agreement includes, among other aspects:

- The purpose of the Agreement is to establish the legal regime applicable to the processing of personal data that is processed or may be processed by the data processor, under the service provision contracts signed between the parties, which are under the ownership and control of the data controller.
- The data processor is obliged to process the data in accordance with the instructions of the data controller.
- The data processor shall apply technical and organizational security measures to ensure an adequate level of security.
- The data processor is authorized to subcontract the companies reflected in Annex A of the Agreement – Subcontracting. The subcontractor, who also has the status of data processor, is equally obliged to comply with the obligations established in the Agreement for the data processor and the instructions issued by the data controller.

Regarding security measures

RSI indicates that the planning for the development of the NBE extends from 2019 to 2022 and that during December 2019, a risk analysis of the NBE was conducted for both the Web version and the App. The following areas were analyzed:

(...)

From the Client Management processing, RSI indicates that a data protection risk analysis has been conducted by the Data Protection Officer. This analysis is performed with an initial review of the list of threats and the assessment of whether they apply to the processing or not, and provides the threat assessment questionnaire and a second part, where the risk analysis is conducted according to RSI's risk analysis methodology. The result of this analysis is provided.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/58

RSI indicates that (...) and that in compliance with this line of work, three security assessments have been conducted on Ruralvía Clásica, the reports of which are provided:

- Report prepared by the company ***COMPANY.1, dated 28/02/2022.
- Report prepared by the company ***COMPANY.1, dated 28/04/2022.
- Report prepared by the company ***COMPANY.2, continuous evaluation reflecting the tests conducted between 01/10/2021 and 30/04/2023, where all critical vulnerabilities are closed.

The report prepared by the Cybersecurity department of RSI is also provided, which lists the three security assessments conducted by a third party and the status of the resolution of the detected vulnerabilities.

Likewise, (...) an ethical hacking audit was conducted in June 2022 by an external provider. The audit report is attached and states:

(...)

RSI, in its submission dated 11/10/2023 to the AEPD, explains:

(...)

Additionally, the audits conducted after those mentioned in the previous information requests in compliance with the fraud plan are listed:

(...)

Similarly, the latest audit of compliance with security measures (...) to comply with the PSD2

Delegated Regulation is provided, with the audited period from December 15, 2021, to December 15,

2022. The report is dated December 15, 2022. Specifically, it focused on reviewing the information associated with the security measures related to enhanced authentication measures across the various channels and payment services offered by RSI. The Audit Report prepared by the firm ***COMPANY.3 is attached.

To address the detected vulnerabilities in accordance with the compliance level with the PSD2 regulation, RSI proceeds to implement an action plan. The current status of the Action Plan is provided.

(...)

This is why the implemented security measures did not prevent the incident.

(...)

Technical and organizational measures adopted to avoid, as much as possible, incidents like the one that occurred.

In addition to the measures described above, RSI conveys:

(...)

RSI, in its submission dated 11/10/2023 to the AEPD, details the operation of these controls:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/58

Throughout February 2023, the following actions were carried out:

(...)

Regarding communication to the affected parties

The respondent and 9 other entities of the Group have communicated the breach to all affected clients who are natural persons.

There are another 9 entities that have communicated the breach to all affected clients who are natural persons and who have an Electronic Banking Agreement.

And another 7 have not communicated the breach to all affected clients who are natural persons:

The model of communication to the affected parties by the breach is provided, which includes the contact details of the DPO of the Entity and describes the possible consequences of the incident for those affected.

Information about the recurrence of these events and the number of similar events that have occurred over time

RSI states that these events are not recurrent, being this the first occasion they have occurred.

It also notes that they have not heard from their Cyber Threats service regarding the publication of data on the dark web.

THIRD: On 23/01/2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against CAJAZAMORA for the alleged violations of Articles 5.1.f), 32.1, and 33.1 of the GDPR, classified under Articles 83.5.a) and 83.4.a) of the GDPR.

This initiation agreement, which was notified to CAJAZAMORA in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was recorded on 23/01/2024, as evidenced by the acknowledgment of receipt in the file.

FOURTH: After the initiation agreement was notified, CAJAZAMORA requested, by letter dated 29/01/2023, a copy of the documents that made up the administrative file and an extension of the deadline to submit allegations and propose relevant evidence.

By letter dated 05/02/2024, the instructor extended the deadline to submit allegations for a maximum of ten days, counted from the day following the receipt of the copy of the file.

On 26/02/2023, the instructor of the file sent a written notice to the data controller indicating that "Since a large part of the documentation in the file has been provided by RSI through the General Electronic Registry, the registration numbers of the submitted documents were grouped by dates, so that within

10 working days, they could communicate if there were documents, or parts of documents, that they considered should not be provided to the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/58

the claimed party, due to reasons related to trade secrets, personal data protection, or others.

On 11/03/2024, the data processor stated that "regarding its transfer to the claimed party, my client considers that it is not up to them, but rather to the AEPD to assess the legality of such transfer and/or, if applicable, the existence of any impediments or limitations that the applicable regulations may establish."

On 16/04/2024, the instructor of the procedure sent two documents to the claimed party: one, providing a copy of the administrative file in accordance with the provisions of Article 53.1 a) of the LPCAP, and, independently, a second one in which the key and hash are provided that will allow access to the documentation included in the physical support.

On 29/04/2024, CAJAZAMORA submitted a written statement of allegations summarizing the following:

- That all procedures (26) opened against the entities belonging to the Caja Rural Group be accumulated due to the close connection and substantial identity; the absence of culpability of the claimed party in this case;
- The impact on the principles of sanctioning law as a consequence of the interpretation made by the AEPD;
- Non-existence of a violation of Article 32.1 of the GDPR;
- Non-existence of a violation of Article 5.1.f) of the GDPR;
- Non-existence of a violation of Article 33 of the GDPR;
- Violation of the principle of proportionality in determining the sanctions;
- That the proceedings be archived or a warning sanction or a significant reduction of the sanction be agreed upon.

FIFTH: On 21/10/2024, the opening of a period for the practice of evidence was agreed upon, establishing the following:

- To consider as reproduced for evidentiary purposes the complaint filed by the complainant and its documentation, the documents obtained and generated by the Inspection Services that are part of the file.
- To consider as reproduced for evidentiary purposes the allegations to the initiation agreement presented by the claimed party and the accompanying documentation.
- To request the claimed party to provide documentation proving that, if applicable, they had commissioned or instructed their data processor to notify the AEPD of the personal data breach subject to this sanctioning file and the accreditation of both the aforementioned commission and the terms contained therein, along with the date of the same.

On 05/11/2024, the claimed party responded to the evidence presented, the content of which is included in the file.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/58

SIXTH: Attached as an annex is a list of documents in the procedure.

From the actions taken in this procedure, the following have been accredited,

PROVEN FACTS

FIRST:

As stated in the power of attorney granted by CAJA RURAL DE ZAMORA, with C.I.F (...), dated

03/04/2003, before (...).

It is governed by the provisions of its Statutes and, in matters not provided for therein, by Law 13/1989, of May 26, on Credit Cooperatives, its implementing regulations, and other provisions that, in general, regulate the activity of credit entities, applying, on a supplementary basis, cooperative legislation. Likewise, as stipulated in its Statutes, it enjoys its own legal personality and full capacity to act.

SECOND:

On 25/04/2023, CAJAZAMORA submitted, along with the written allegations to the initiation agreement, "Agreement to modify the data protection clause of the service provision contracts signed between CAJAZAMORA and RSI dated 28/12/2018 and signed on behalf of CAJAZAMORA by Mr. A.A.A..

In this Agreement, it is specified:

"ON THE ONE HAND, CAJAZAMORA (hereinafter, Data Controller), with C.I.F (...), with address at (...), 49013 ZAMORA, and represented in the signing of this Contract by Mr. A.A.A., with D.N.I ***NIF.1.

AND

ON THE OTHER HAND, RSI (hereinafter, Data Processor), with C.I.F B-80458417, with address at Avda. de la Industria, 23-28760 Tres Cantos (Madrid), and represented in the signing of this Contract by Mr. B.B.B. with D.N.I ***NIF.2."

In this agreement, it is indicated that,

"The purpose of the Agreement is to establish the legal regime applicable to the processing of personal data that may be processed by the data processor, by virtue of the service provision contracts that are signed between the parties, and that are under the ownership and control of the data controller.

The data processing activities provided for are those strictly necessary for the provision of the services provided in the main contract. The treatments that could be carried out by RSI, the type of information to be processed, and the categories of data subjects whose data could be processed are defined."

In the Agreement itself, it is indicated, in its section 3, relating to the Obligations of the Data Processor, that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/58

"The Data Processor and all its personnel are obliged to:

a) Use the personal data subject to processing, or those collected for its inclusion, solely for the purpose of this assignment. Under no circumstances may the data be used for any other purpose, whether for their own benefit or that of third parties. To carry out any other activity aimed at the processing or use of the data files of the Data Controller, prior written consent from the Data Controller will be required.

b) Process the data in accordance with the instructions of the Data Controller.

(...)"

Regarding the notification of "data security breaches," it is specified in section 3.3 that:

"The Data Processor shall notify the Data Controller, without undue delay, and in any case, before the maximum period of 36 hours, and through the DPO, of any data security breaches concerning the personal data in its charge of which it becomes aware, together with all relevant obligations for the documentation and communication of the incident.

(...)"

Section 3.4 concerning security measures states that:

"The Data Processor, in accordance with the provisions of Article 32, shall apply those technical and organizational measures appropriate to ensure a level of security adequate to the risk of processing detected in each case, considering the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probability and severity risks to the rights of individuals at any given time.

In any case, it must implement mechanisms equivalent to those used by the Data Controller to:

- a. Ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services.
- b. Restore the availability and access to personal data quickly in the event of a physical or technical incident.
- c. Regularly verify, evaluate, and assess the effectiveness of the technical and organizational measures implemented to ensure the security of processing.
- d. Pseudonymize and encrypt personal data, where applicable.

The technical and organizational measures to be implemented by the Data Processor are reflected in Annex B of this agreement - Security Measures.

The Data Processor is authorized to subcontract to the companies reflected in Annex A of the Agreement - Subcontracting. The subcontractor, who also has the status of Data Processor, is equally obliged to comply with the obligations established in the Agreement for the Data Processor and the instructions issued by the Data Controller.

Regarding the obligations of the Data Controller, it is indicated in section 4 of the Agreement:

"It is the responsibility of the Data Controller:

- a) To provide the Data Processor with the necessary data for the provision of the service.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/58

- b) If legally required, to carry out a data protection impact assessment of the processing operations to be carried out by the Data Processor.
- c) To carry out the necessary prior consultations.
- d) To ensure, prior to and throughout the processing, compliance with the GDPR by the Data Processor.
- e) To supervise the processing, including conducting inspections and audits."

In section 5, the DPO of the Data Processor and the Data Controller is identified respectively.

Regarding CAJAZAMORA, the DPO is listed as:

"Identification Mr. A.A.A.

Contact ***EMAIL.1".

Regarding RSI, the DPO is listed as:

"Identification Ms. C.C.C.

Contact ***EMAIL.2".

Section 6 of the Agreement on "Liability" states that,

"If the Data Processor, or in its case, the contractors, breach this Agreement or the applicable regulations by determining the purposes and means of processing, they will be considered responsible for the processing concerning such processing.

In the event that a supervisory authority sanctions the Data Controller as a direct consequence of the Data Processor's failure to comply with the stipulations of this Agreement, the Data Processor shall indemnify the Data Controller as stipulated in the liability clause of the framework contract in force between the parties."

THIRD:

In the "Agreement to amend the data protection clause of service provision contracts," signed between CAJAZAMORA and RSI, dated in Zamora on 28/12/2018, Annex B - Security Measures to the Agreement to amend the data protection clause of service provision contracts indicates that RSI holds the following certifications:

(...)

FOURTH:

On 11/01/2023, a personal data breach of CAJAZAMORA was reported to the Division of Technological Innovation of this Agency, with entry number REGAGE(...). This notification was sent by

RSI, the Data Processor of CAJAZAMORA. Attached to this notification is the "Final Security Incident Report."

FIFTH:

CAJAZAMORA had the electronic banking application called Ruralvía Clásica for the purpose of providing online banking services to its clients.

CAJAZAMORA wished to change this application to a new electronic banking application called Nueva Banca Electrónica (NBE).

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/58

Dated April 14, 2023, in response to the request made by the AEPD, RSI states that:

(...)

SIXTH:

Regarding the establishment of a banner in the Ruralvía Clásica application that linked to the new NBE application and its operation, in the "Incident Analysis Report of Security," dated December 9, 2022, which RSI provided concerning the personal data breach of CAJAZAMORA, it is indicated:

"(...)"

Furthermore, on April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, RSI responds that:

"(...)"

SEVENTH:

(...)

On April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, a document 9 titled "Web Application Audit" was submitted, in which it is indicated (...):

"(...)"

EIGHTH:

(...)

NINTH:

Regarding how the personal data breach occurred, on April 14, 2023, RURALVÍA, in response to the information request made by this Agency, states the following,

"(...)"

Additionally, in the "Incident Analysis Report of Security Final Report," dated December 30, 2022, which RSI provided concerning the personal data breach of CAJAZAMORA, it is indicated in section 1.4.2, "How was the problem detected or how did it happen?", that:

"(...)"

TENTH:

Furthermore, in the "Incident Analysis Report of Security Final Report," dated December 30, 2022, which RSI provided concerning the personal data breach of CAJAZAMORA, in section 1.4.1, "What happened?", it is indicated that the personal data breach occurred due to a vulnerability in the SSO system, stating that:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/58

ELEVENTH:

Regarding the attack pattern used by the cybercriminal, on April 14, 2023, in response to the request

made by the AEPD within the framework of the preliminary investigation proceedings, RSI indicates that,

(...)

The same provision is contained in section 1.4.2 of the "Incident Analysis Report of Security Final Report," dated December 30, 2022, which RSI provided concerning the personal data breach of CAJAZAMORA.

TWELFTH:

Regarding the causes that allowed the personal data breach, in the "Incident Analysis Report of Security Final Report," dated December 30, 2022, which RSI provided concerning the personal data breach of CAJAZAMORA, it is indicated, in section 3, "Cause Analysis" that:

"(...)"

THIRTEENTH:

In response to the information request made by the AEPD within the framework of the preliminary investigation proceedings, RSI responds on May 26, 2023, providing as document 8 an email dated September 28, 2022, before the higher volume of accesses occurred (between November 10 and 23 of the same month) and the personal data breach was detected, sent by (...), in which it is indicated: (...)

In the same vein, as previously indicated, on April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, RSI responds that,

"(...)"

On April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, a document 9 titled "Web Application Audit" was submitted, in which it was indicated that,

"(...)"

FOURTEENTH:

On April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, a document 9 titled "Web Application Audit" was submitted, in which the (...).

(...)

FIFTEENTH:

Regarding the detection of the personal data breach, in the "Incident Analysis Report of Security Final Report," dated December 30, 2022, which RSI provided concerning the personal data breach of CAJAZAMORA, it is indicated in section 1.4.1, "What happened?", that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/58

(...)

Therefore, although the breach was detected on December 7, 2022, previous accesses to that date are confirmed, with the highest volume of accesses occurring between November 10 and November 23, 2022.

Regarding the measures adopted on November 23, 2022, the aforementioned document indicates that,

"(...)"

Therefore, these measures were adopted before the detection of the personal data breach (on December 7, 2022) and as a consequence of actions taken to increase the security of electronic banking.

SIXTEENTH:

As for the mitigating measures applied after the personal data breach, in the "Final Incident Analysis Report" dated December 30, 2022, which RSI provided in relation to the personal data breach of CAJAZAMORA, it states that,

"(...)"

SEVENTEENTH:

Subsequently, within the framework of the definitive implementation of the new NBE application, a series of actions are carried out, as noted in the "Final Incident Analysis Report" dated December 30, 2022, which RSI provided in relation to the personal data breach of CAJAZAMORA, stating that, "(...)"

EIGHTEENTH:

Regarding the personal data accessed by the attacker, in the "Final Incident Analysis Report" dated December 30, 2022, which RSI provided in relation to the personal data breach of CAJAZAMORA, it indicates which personal data may have been accessed, (...)

NINETEENTH:

The notification forms of the breach that accompany the Security Incident Report prepared in all cases by RSI, the data processor, as stated in the preliminary investigation report dated November 27, 2023, determine that the number of individuals affected by the personal data breach of CAJAZAMORA is 4 users, who were notified of the personal data breach.

TWENTIETH:

During the period of evidence practice referred to in the Fifth Background, CAJAZAMORA provided the following documents regarding the notification of the personal data breach to the AEPD:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/58

- Email dated December 13, 2022, sent by RSI to CAJAZAMORA, in its capacity as data processor, communicating the security incident, indicating that they were preparing a report on it and the steps to be taken (notification to the AEPD and communication to the affected parties) and requesting validation from CAJAZAMORA as the data controller. Thus, it communicates that:

"(...)"

After conducting the appropriate triage, the incident requires communication to the AEPD and the affected clients, so we have a margin of 72 hours from its notification to communicate it to the control authority.

In this regard, we can submit the notification to the AEPD as data processors, on behalf of the Entity. For this, we need, please, your agreement as a response to this email."

"(...)"

- Declaration of responsibility dated November 4, 2024, from the General Director of CAJAZAMORA, in which he declares that,

"On December 9, 2022, RURAL SERVICIOS INFORMÁTICOS S.L. (RSI), in its capacity as data processor for this entity, communicated to it the report on the security breach that occurred in its systems, requesting instructions regarding the notification of the incident, both to the Spanish Agency for Data Protection and to the affected parties, in accordance with the provisions of Articles 33 and 34 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, regarding the protection of natural persons with regard to the processing of personal data and on the free movement of such data. In particular, instructions were requested from this entity regarding the possibility of notifying the security breach to the aforementioned Agency by RSI, as the data processor for CAJAZAMORA.

Given the urgency of this situation, on the same date that the aforementioned email was received, verbal instructions were given by this entity to RSI, so that it could proceed immediately to notify the security breach to the Spanish Agency for Data Protection, acting in any case on behalf of and for the account of CAJAZAMORA."

- Email dated December 15, 2022, sent by RSI to CAJAZAMORA, in which it communicates that it had proceeded to notify the security breach to the AEPD, in response to the instructions given by its represented party. Thus, it communicates that:

“(...)

On the other hand, I am sending you the proof of the communication of the breach to the AEPD.”

TWENTY-FIRST:

According to the diligence dated January 19, 2024, in the file, the business volume (gross margin) of CAJAZAMORA during the fiscal year 2022 amounts to (...) euros.

LEGAL GROUNDS

I

Competence

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/58

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In the case examined, in accordance with the provisions of Article 4.1 of the GDPR, it is established that the processing of personal data is taking place, since CAJAZAMORA collects and retains personal data from both natural and legal persons, its clients, (...).

CAJAZAMORA carries out this activity in its capacity as the data controller, as it is the entity that determines the purposes and means related to the processing of personal data, by virtue of Article 4.7 of the GDPR. Therefore, if it decides the "why" and the "how" personal data should be processed, it must assume its responsibility.

Moreover, the data controller must also ensure the application of technical and organizational measures that guarantee the security of personal data when carrying out the processing. And it must be able to demonstrate compliance with the GDPR and the LOPDGDD.

On its part, Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, alteration of, or unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed."

In the present case, there is a security incident categorized as a security breach, having occurred due to unauthorized access to personal data.

There are indications that the personal data breach occurred as a result of a change in the access application to the entities. To prevent the client from having to identify themselves twice, when the client enters the original application that they are familiar with (and which is going to be changed) to access their client area of the entity, they are automatically redirected to the new application that is being implemented.

To do this, a code was generated by the originating application that was verified in the destination application. However, this latter application did not verify that the user and entity that had connected to the previous application, the original one, was the same user connecting to the new one. In this way, the attacker allegedly could modify that code and connect to the second application as a different user. As indicated in the investigation report, the Boxes detected an increased volume of accesses starting from 10/11/2022, that is, before they detected the breach, and they incorporated a solution on November 23. As a result, the problem that led to the breach was apparently resolved.

It should be noted that the identification of a personal data breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the controllers and processors and the security measures applied.

Among the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data are guaranteed in paragraph 1.f).

On the other hand, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of processing, notification to the supervisory authority, and communication to the data subject, respectively.

As previously stated, it is presumed that the data controller is the entity that has the true capacity to exercise control over the data, who determines the why and how the data should be processed.

Furthermore, according to the diligence dated 19/01/2024 in the file, the business volume (gross margin) of CAJAZAMORA during the year 2022 amounts to (...) euros.

III

Description of the Personal Data Breach

CAJAZAMORA had the electronic banking application called Ruralvía Clásica for the purpose of providing online banking services to its clients.

For a client to enter the Ruralvía Clásica application and log in, they needed to enter their identifier, password, and NIF.

CAJAZAMORA wanted to change that application to a new electronic banking application, called Nueva Banca Electrónica (NBE).

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/58

IV

Unfulfilled obligation: infringement of Article 5.1(f) of the GDPR.

Article 5.1(f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

(...)

Thus, as stated in the eighteenth proven fact, regarding the personal data to which the attacker had access, the "Final Security Incident Analysis Report," dated 30/12/2022, indicates that,

(...)

Although the personal data breach was detected on 07/12/2022, prior accesses to that date are confirmed, noting that the highest volume of accesses occurred between 10 November and 23/11/2022.

In this regard, in the aforementioned report of 30/12/2022, as stated in the ninth and fifteenth proven facts, it is indicated in section 1.4.2, How was the problem detected or how did it happen?, that:

(...)

The attacker was able to access those personal data of CAJAZAMORA customers due to the lack of appropriate technical and organizational measures prior to the occurrence of the personal data breach. First, it should be noted that, as stated in the twelfth proven fact, regarding the causes that allowed the personal data breach, in the "Final Security Incident Analysis Report," dated 30/12/2022, in section 3, "Cause Analysis," it states:

(...)

Secondly, in the fifteenth proven fact, the implemented mitigating measures are recorded, which

highlight the absence of appropriate technical and organizational measures to prevent the occurrence of the breach, emphasizing, for such purposes,
(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

18/58

In conclusion, and in accordance with all that has been indicated, it has been established that the violation of the principle of confidentiality that indeed occurred, as the attacker accessed multiple personal data of CAJAZAMORA customers, was possible due to the lack of appropriate technical and organizational measures highlighted by the aforementioned vulnerabilities.

The number of customers affected by the breach (...).

The documentation in the file provides clear evidence that CAJAZAMORA violated Article 5.1(f) of the GDPR, "Principles relating to processing," by not adequately ensuring the confidentiality and integrity of personal data as a result of the personal data breach that occurred.

Furthermore, (...).

In accordance with the evidence available in this proposal for resolution of the sanctioning procedure, it is considered that the known facts could constitute an infringement attributable to CAJAZAMORA for violation of Article 5.1(f) of the GDPR.

V

Classification for the infringement of Article 5.1(f) of the GDPR

In accordance with the evidence available and without prejudice to what may result from the instruction, it is considered that CAJAZAMORA did not adequately guarantee the confidentiality and integrity of personal data.

The infringement attributed to the entity is classified under Article 83.5(a) of the GDPR, which considers that the infringement of "the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9" is subject to sanction, in accordance with paragraph 5 of the aforementioned Article 83 of the cited Regulation, "with administrative fines of up to €20,000,000 or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount."

The LOPDGDD in its Article 71, Infringements, states that: "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

And in its Article 72, it considers for the purposes of prescription that they are: "Infringements considered very serious:

1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, those infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and will prescribe in three years, particularly the following:

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/58

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.

(...)

VI

Proposal for a sanction for the infringement of Article 5.1(f) of the GDPR

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
 - b) the intentionality or negligence in the infringement;
 - c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
 - d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
 - e) any previous infringements committed by the controller or processor;
 - f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
 - g) the categories of personal data affected by the infringement;
 - h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
 - i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;
 - j) adherence to codes of conduct pursuant to Article 40 or to certification mechanisms approved under Article 42, and
 - k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.
- In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, “Sanctions and corrective measures,” establishes that:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/58

“2. According to the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The ongoing nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having a data protection officer when not mandatory.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms in cases where there are disputes between them and any interested party.”

According to the transcribed provisions, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the GDPR for which CAJAZAMORA is held responsible, the following factors are deemed concurrent:

- The nature, gravity, and duration of the infringement; the facts revealed affect a basic principle

related to the processing of personal data, such as confidentiality and integrity, which the regulation penalizes with the utmost severity as it allows, as a consequence of the personal data breach, access to personal data by unauthorized third parties, with the harm that this may entail.

- The number of affected parties: (...)
- Regarding the level of damages caused: (...) since users who had access to Electronic Banking would have been able to access this type of data (account number(s) and balance(s)). Additionally, it should be noted that this situation allows access to the data, which can lead to the materialization of the risk of identity theft, among others (Article 83.2.a) of the GDPR).
- The intent or negligence in the infringement. There is a lack of diligence in complying with the obligations imposed by data protection regulations, allowing access by cybercriminals to personal data, thus violating its confidentiality; in this regard, the SAN of 17/10/2007 can be cited, which, although issued before the GDPR came into force, is perfectly extrapolable to the case we are analyzing. The ruling, after stating that entities whose activities involve continuous processing of client and third-party data must observe an adequate level of diligence, specified that "(...) the Supreme Court"

21/58

It is understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, particular weight must be given to the professionalism or lack thereof of the individual, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and extensive handling of personal data, there must be an emphasis on rigor and exquisite care to comply with the legal provisions in this regard (Article 83.2, b) of the GDPR).

- The activity of the allegedly infringing entity is linked to the processing of personal data of both clients and third parties. In the activity of the claimed entity, the processing of personal data is essential; therefore, given its purpose and business volume, the significance of the conduct subject to this claim is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

For the purpose of deciding on the proposal for the fine and its amount, in accordance with the available evidence, taking into account the criteria of Article 83.2 of the GDPR regarding the infringement committed, violation of Article 5.1.f) of the GDPR, it is considered appropriate to propose a sanction of 15,000 euros.

VII

Infringement of Article 32.1 of the GDPR.

Article 32 of the GDPR "Security of processing" establishes that:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular attention shall be paid to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element

C/ Jorge Juan, 6

www.aepd.es

to demonstrate compliance with the requirements established in paragraph 1 of this article.

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data following the instructions of the controller, unless required to do so by Union or Member State law.”

Having reviewed the allegations made by CAJAZAMORA, and in light of them, having examined the documentation in the administrative file and that provided by the responding party, it is evident that all the technical and organizational security measures whose absence has been proven, directly enabling the personal data breach, do not constitute a violation, in this specific case, of Article 32 of the GDPR as the absence of other independent technical and organizational security measures unrelated to the personal data breach has not been substantiated.

VIII

Violation of Article 33.1 of the GDPR

Article 33 of the GDPR, “Notification of a personal data breach to the supervisory authority,” establishes that,

“1. In the case of a personal data breach, the data controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after becoming aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by the reasons for the delay.

2. The data processor shall notify the data controller without undue delay of any personal data breaches of which it becomes aware.

3. The notification referred to in paragraph 1 shall, at a minimum:

a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects affected, and the categories and approximate number of personal data records affected;

b) communicate the name and contact details of the data protection officer or another contact point where more information can be obtained;

c) describe the possible consequences of the personal data breach;

d) describe the measures taken or proposed by the data controller to remedy the personal data breach, including, where appropriate, the measures taken to mitigate the possible negative effects.

4. If it is not possible to provide the information simultaneously, and to the extent that it is not possible, the information shall be provided gradually without undue delay.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/58

5. The data controller shall document any violation of the security of personal data, including the facts related to it, its effects, and the corrective measures adopted. Such documentation will allow the supervisory authority to verify compliance with the provisions of this article.

On 21/10/2024, it was agreed to open a testing period in which point 3 indicated that it was agreed to require CAJAZAMORA:

"To provide documentation proving that, if applicable, it had instructed its data processor to notify the AEPD of the personal data breach subject to this sanctioning file. Accreditation of both the aforementioned instruction and the terms contained therein, as well as the date of the same."

The investigated party submitted in response to this requirement on 05/11/2024, the following documents:

- Email dated 13/12/2022, sent by RSI to CAJAZAMORA, in its capacity as data processor, in which it communicates the security incident, indicating that they were preparing a report on it and the steps to

be taken (notification to the AEPD and communication to the affected parties) and requesting validation from CAJAZAMORA as the data controller. Thus, it communicates that:

“(…)

After conducting the corresponding triage, the incident requires its communication to the AEPD and the affected clients, so we have a margin of 72 hours from its notification to communicate it to the supervisory authority.

In this regard, we can submit the notification to the AEPD as data processors, on behalf of the Entity. For this, we need, please, your consent as a response to this email.”

“(…)

- Declaration of responsibility dated 04/11/2024 from the General Director of CAJAZAMORA, in which he declares that,

"On December 9, 2022, RURAL SERVICIOS INFORMÁTICOS S.L. (RSI), in its capacity as data processor of this entity, communicated to it the report on the security breach that occurred in its systems, requesting instructions regarding the notification of the incident, both to the Spanish Data Protection Agency and to the affected parties, in accordance with the provisions of Articles 33 and 34 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data. In particular, instructions were requested from this entity regarding the possibility of notifying the security breach to the aforementioned Agency by RSI, as the data processor of CAJAZAMORA.

Given the urgency of this situation, on the same date that the aforementioned email was received, this entity verbally issued instructions to RSI, so that it could proceed immediately to notify the security breach to the Spanish Data Protection Agency, acting in any case on behalf of and for the account of CAJAZAMORA.”

- Email dated 15/12/2022, sent by RSI to CAJAZAMORA, in which it communicates that it had proceeded to notify the security breach to the AEPD, in response to the instructions given by its represented party. Thus, it communicates that:

“(…)

On the other hand, I am sending you the proof of the communication of the breach to the AEPD.”

Analyzing the documentation submitted by CAJAZAMORA referred to in the twentieth proven fact, RSI (responsible declaration in a private document by the highest responsible of the entity, based on a request for prior instructions from the data processor and with the immediate subsequent action of notifying the personal data breach to the AEPD) it is determined that the investigated party has provided in response to the evidence practice carried out by this Agency on 21/10/2024 regarding the accreditation of the instructions provided to its data processor, so that it could proceed to the notification on its behalf to the AEPD of the personal data breach subject to the aforementioned procedure, in accordance with Article 33 of the GDPR.

Therefore, it must be concluded that, after analyzing the investigated facts, the allegations made by the claimed party, and the evidence provided in the procedure, considering the concurrent circumstances in the specific case, the filing of the alleged infringement in relation to Article 33.1 of the GDPR would be appropriate.

IX

Response to the allegations made regarding the initiation agreement

In relation to the allegations made by CAJAZAMORA regarding the initiation agreement, a response is provided according to the order in which they are presented in their writing:

FIRST. ON THE ACCUMULATION OF PROCEDURES TO THE ENTITIES OF THE GROUP.

1. Preliminary considerations

According to CAJAZAMORA: “All of the initiation agreements in the files that have just been referenced arise, as indicated, from the security breach analyzed by the Initiation Agreement” and subsequently states that “we are faced with a single fact, referring to a single breach, suffered during the development of the aforementioned tool carried out by RSI in its capacity as data processor and which, however, is fragmented by the...

AEPD in twenty-six differentiated procedures processed against twenty-six distinct entities”

In response to these preliminary considerations, it should be noted that the responding party confuses the factors that determined the vulnerability being similar in all the procedures initiated by this Agency with the idea that only a single breach of personal data has occurred.

We are faced with incidents that have affected 26 entities that are completely independent, both legally and economically. Each of these entities is responsible for the processing of data of its clients in a differentiated manner, and, consequently, there are as many personal data security breaches as there are data controllers who have failed to comply with the obligations imposed by the GDPR. Each entity is responsible for the processing of its own data and regarding its own clients.

All the entities referred to by the responding party in its written allegations had contracted with RSI, (...)

However, the fact that RSI was the same data processor for all the entities does not mean that one can speak of “a single fact, referring to a unique breach.”

Each entity, as the data controller of its clients, autonomously made the decision to contract with RSI as the data processor, for which each of them signed their own data processing agreement, on differentiated dates, signed by different persons with sufficient authority for this in each of the rural banks and with reference to their different data protection delegates, who are not the same.

Furthermore, as also stated in the proven facts, both the “Security Incident Analysis Report,” dated 09/12/2022, and the “Final Security Incident Analysis Report,” dated 30/12/2022, were carried out individually for each of the rural banks, containing their own specificities.

Likewise, once the personal data breach occurred, the actions of each of the entities were not the same, with each acting autonomously, both in relation to the AEPD (some banks have notified the personal data breach directly and others have entrusted their data processor to carry it out), as well as towards their respective clients and independently of the actions of the others.

2. Regarding the accumulation of administrative procedure files.

In this allegation, the responding party considers that: “The legal regime for the accumulation of procedures, as well as processes, in the administrative field responds to the central idea of connectivity, that is, that the instruction work that must be carried out is favored by the appreciation of the subject as a whole.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

raised and the possibility that the joint viewing work allows for a better assessment of the elements that enable the application of the norm to the specific case.”

Article 57 of the LPACAP regarding the accumulation of procedures establishes that: “The administrative body that initiates or processes a procedure, regardless of the manner of its initiation, may, ex officio or at the request of a party, order its accumulation with others that have substantial identity or intimate connection, provided that it is the same body that must process and resolve the procedure. No appeal shall be allowed against the accumulation agreement.”

Consequently, both the administrative body that initiates the procedure and the one that processes it may order its accumulation with other procedures that have substantial identity or intimate connection, as long as it is the same body that must process and resolve the procedure.

Article 57 of the LPACAP grants administrative bodies the authority for better management of the procedures they process, allowing for their accumulation as long as there is substantial identity or intimate connection among them. Therefore, it is a possibility available to the Administration, which is not obliged to proceed with the accumulation if requested, although it is required to make a reasoned decision in this regard, as occurs in the present sanctioning procedure.

3. Response to the allegation seeking the accumulation of sanctioning procedures.

In this allegation, the responding party considers that: “The legal regime of the accumulation of procedures, as well as of processes, in the administrative sphere responds to the central idea of

connectivity, that is, that the instructional work to be carried out is favored by the appreciation of the issue as a whole and the possibility that the joint viewing work allows for a better assessment of the elements that enable the application of the norm to the specific case."

It should be noted that the claims of the responding party are not supported by Article 57 of the LPACAP, nor by any type of jurisprudence or doctrine that attributes to accumulation the purpose of providing the decision-making body with a better assessment of the elements of the case.

The institution of accumulation is a technique of administrative simplification that allows the competent body to process and resolve in a main procedure the possibility of accumulating with those others that have substantial identity or intimate connection, for the purpose of simultaneous processing and resolution. The instrumental nature of accumulation is determined by the first limit established by Article 57 of the LPACAP, which is that the body "must be the same body that must process and resolve the procedure."

It is a procedural act that cannot be appealed, as established by Article 57 of the LPACAP itself, unlike what is provided in Article 112.1 of the same regulation, which does allow for the challenge of other procedural acts when they "directly or indirectly decide the substance of the matter."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/58

"determining the impossibility of continuing the procedure, causing defenselessness or irreparable harm to legitimate rights and interests."

However, when the LPACAP excludes the possibility of appeal, it is because it applies to the accumulation of procedures, as a procedural act, none of the assumptions of Article 112.1 of the LPACAP that we have just reproduced.

With these arguments as a starting point, the allegations made by the responding party must be completely dismissed, to which a specific response will also be provided.

A) Existence of "intimate connection" or "substantial identity."

The responding party reiterates the idea referred to in the preliminary considerations of this FIRST allegation, stating that "a single breach of personal data security occurred, notified by each of the responsible parties (directly or through their data processor RSI)." It continues to assert that "the connectivity, in this case, derives from the fact that it is a matter of determining responsibility for twenty-six legal entities, but for the same fact."

As already substantiated in the response to the preliminary considerations of this FIRST allegation, it cannot be said that there was a single breach of personal data security; rather, as many breaches of personal data security have occurred as there are entities, all of which are independent of each other, each responsible for its own processing and regarding its own clients, whose systems have suffered a security breach.

For the responding party, there is a single fact upon which responsibilities can be demanded, the security incident in the field of information technology. However, beyond the breach of personal data itself, there has been a loss of confidentiality of the personal data of the clients of each of the entities, which cannot be encompassed as a single fact or as the same fact.

In the same way, the facts related to the actions following the knowledge of the security breach by each of the entities must be differentiated. Some entities directly notified the AEPD of the breach, while in others, the communication was made by the data processor at the request of each of the data controllers (in different ways and at different times).

Finally, some entities communicated the loss of confidentiality of their personal data to the affected individuals, complying with the obligation established in Article 34 of the GDPR, while other entities did not send any type of communication.

All these diverse factual elements determine that it cannot be said that, beyond the same IT vulnerability, there exists an "intimate connection" or "substantial identity" that justifies the accumulation of the procedures.

Regarding the ruling of the TSJ Castilla-La Mancha cited in the allegations, the following clarifications

should be made:
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
28/58

1) There is no compliance with an obligation by several persons jointly, therefore the assumption of Article 28.3 of Law 40/15 does not apply. According to Article 28.3 of Law 40/2015, of October 1: “When the compliance with an obligation established by a norm with the rank of Law corresponds to several persons jointly, they shall be jointly liable for the infringements that, if applicable, are committed and for the sanctions imposed. However, when the sanction is monetary and it is possible, it shall be individualized in the resolution based on the degree of participation of each responsible party.”

In the present case, it cannot be said that there is joint liability, as it does not concern a joint obligation of CAJAZAMORA with the other entities referred to in its written allegations. The facts constituting the infringement attributed to CAJAZAMORA are in its capacity as the data controller, in accordance with the provisions of Article 4 of the GDPR, so the compliance with the principles and obligations established in the GDPR regarding the data processing of its clients corresponds to it individually, not jointly with the other entities, since, furthermore, there is no joint liability in the GDPR.

It should be noted that the fine imposed on each entity depends on its own circumstances, such as the number of affected clients or its business volume.

The figure of joint controllers of the processing, regulated in Article 26 of the GDPR, would also not be applicable in this case, “when two or more controllers jointly determine the purposes and means of the processing, they shall be considered joint controllers of the processing.” The purposes and means of the processing have been determined by CAJAZAMORA independently of the other entities, in its capacity as the sole data controller of the personal data of its clients.

Finally, the assumption described in the judgment does not apply to CAJAZAMORA in relation to the other entities, in which “the Administration imputes different forms of cooperation or collusion among the three defendants in relation to the same facts.” Here, there can be no talk of any type of cooperation or collusion in the facts, simply the responsibility of each of the Rural Savings Banks, and their relationship with the data processor, due to the regime established in the GDPR.

2) The separate processing of the files does not prevent each entity from presenting its allegations. In the judgment of the TSJ of Castilla La Mancha referred to by CAJAZAMORA, in the Third Legal Basis, it is stated that the plaintiff requested that all proceedings be consolidated in order to adequately exercise the right of defense, “...since they referred to the same facts, and it was expressly warned that processing them separately would constitute a serious violation of the right of defense as it would prevent knowledge of the allegations of the other parties involved and the documents they might submit, all of which could have relevance for the legal qualification.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
29/58

of the facts, the determination of the existence or non-existence of an infringement and of the responsible party for it.”

The non-accumulation of procedures cannot produce any of the harms mentioned in that paragraph of the judgment.

Regarding the documents submitted to the procedure, those relating to the security incident, a series of documents were provided by the data controller during the investigation proceedings (let us remember that both the “Security Incident Analysis Report,” dated 09/12/2022, and the “Final Security Incident Analysis Report,” dated 30/12/2022, were prepared individually for each of the rural banks, containing their own specificities), access to which has been guaranteed to all affected entities through the sending, upon request, of a copy of the file. Those documents submitted by the entities responsible

for the processing, which affect them individually, will be taken into consideration in the corresponding procedure.

3) CAJAZAMORA reiterates the need for the “accumulated analysis of the files,” when the judgment of the TSJ of Castilla La Mancha does not include this idea. The need for accumulation is based on other considerations than those expressed by CAJAZAMORA. As we have analyzed:

- Reference is made to the access of the documents in the file that may be submitted by different responsible parties, a matter that we see is guaranteed here.
- The possibility of establishing joint liability is mentioned, which, as we have substantiated, does not apply under the regime established in the GDPR. We must not confuse joint liability under Article 28 of the LRJSP with the co-responsibility under Article 26 of the GDPR, which also does not apply in this case, since, as we stated, under no circumstances are the other Rural Banks co-responsible for the processing of customer data of the other entities.
- There is no type of cooperation or collusion among the various Rural Banks in the facts. These figures must be ruled out due to the relationship between the Rural Banks, which are independent entities, each responsible for the processing of their customers, nor, as we have said previously, regarding the special regime established by the GDPR concerning the relationship between the data controller and the data processor.

B) That the same body is responsible for the processing and resolution of the procedure.

The processing of the various sanctioning procedures corresponds to the same body, as CAJAZAMORA points out, which does not determine the mandatory nature of the decision to accumulate the procedures, especially when there are no circumstances that imply the defenselessness of CAJAZAMORA.

4. Connectivity in the sanctioning field

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/58

In this allegation, CAJAZAMORA points out that the Constitutional Court has declared that both the substantive principles of Article 25.1 of the Spanish Constitution (CE) and the procedural guarantees of Article 24.2 CE are applicable, with certain nuances, to the exercise of sanctioning power.

4.1. General aspects related to the instruction and its essential functionality.

A) Linkage of the instruction as a consequence of the factual unity.

CAJAZAMORA cites a ruling from the Supreme Court, which states that “the initiation of a single sanctioning procedure for the commission of the same infringing act, with the aim of determining the degree of participation of each alleged responsible party in the commission of the infringement and ensuring that the resolution of the file is coherent...” According to CAJAZAMORA, “In this case, the appellant argued that, since two files were processed, each of the responsible parties was unaware of what was in the other that could benefit or harm them. This is a concrete example of the difficulties that arise in terms of the right to defense in cases of separate processing.”

As previously justified, there are as many breaches of personal data as there are responsible parties for the processing, and we cannot speak of a single infringing act, but rather of a series of infringing acts attributable to a series of independent entities concerning the processing for which they are responsible, regarding their clients; nor can we speak of “degree of participation” among the various entities, nor in terms of the responsible party-processor relationship.

Regarding the documents submitted to the procedure, those related to the security incident, a series of documents were provided by the processor during the investigative proceedings, whose access to all affected entities has been guaranteed through the prior request for a copy of the file. Furthermore, RSI submitted the “Security Incident Analysis Report,” dated December 9, 2022, as well as the “Final Security Incident Analysis Report,” dated December 30, 2022, in a manner individualized for each of the rural banks, containing their specificities.

Those documents submitted by the entities responsible for the processing that affect them individually will be taken into consideration in the corresponding procedure. And, any other documents that may

constitute evidence relevant to the facts will be duly incorporated into the other files ex officio, in accordance with the provisions of Article 75 of the LPACAP, "the necessary instructional acts for the determination, knowledge, and verification of the facts on which the resolution must be pronounced will be carried out ex officio."

B) Connectivity as a fundamental prerequisite for the exercise of the right to defense.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/58

According to CAJAZAMORA, the breakdown of the continuity of the cause, in this case, of the sanctioning administrative procedure implies that the two procedures become "sealed" and that the evidence, allegations, and expert opinions conducted in one cannot be presented contradictorily in the other.

However, a paragraph from the judgment transcribed by CAJAZAMORA is fully applicable to respond to the present allegation: "it is not specified to what extent 'their defense was harmed'," and to reject it, just as the Supreme Court understands "that the decision of the lower court is correct, which considers that the initiation of sanctioning proceedings against each of the companies is justified... due to the clear differentiation of the behaviors attributed and the failure to demonstrate that there was real defenselessness - as reasoned in the contested judgment."

The Constitutional Court in its judgment No. 210/1999, of November 29, indicates that the constitutionally relevant defenselessness is the situation in which, after the infringement of a procedural norm, one of the parties is prevented from exercising the right to defense by eliminating or limiting their power, either to assert rights and interests for them to be recognized, or to dialectically respond to opposing positions in the exercise of the principle of contracting.

As an essential characteristic of defenselessness, it must be material and not merely formal, that is, it is not sufficient for there to be a defect or procedural infringement; there must have been an effective and real right to defense (judgment of the Constitutional Court No. 90/1988, of May 13).

Well then, beyond a generic allegation of the potential defenselessness that could arise from the non-accumulation of the procedures, CAJAZAMORA is unable to present a single defect or procedural infringement that has effectively limited their right to defense, when the allegations presented by the affected Rural Banks regarding the security incident are substantially similar, and they have had access to all the documentation that affects them in a common manner. In any case, the instructing body will incorporate into the procedure and inform CAJAZAMORA of any other documents that may constitute evidence relevant to the facts.

4.2.- The intimate connection as a requirement for the individualization of responsibility for the same facts.

CAJAZAMORA argues that, since we are dealing with a single breach of personal data, the processing of separate procedures for each of the responsible entities may eventually lead to the determination of diverse responsibilities. The intimate connection translates into the principle of uniqueness in determining the concurrence of the facts when, as CAJAZAMORA claims, it concerns unique facts that result in a single breach of personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/58

As previously reasoned, it is not appropriate to speak of a single breach of personal data, but rather of as many breaches as there are data controllers who have suffered the security incident concerning their clients' data.

There cannot be varying degrees of responsibility between CAJAZAMORA and the other entities. Each data controller will have a degree of responsibility that must be determined individually regarding compliance with data protection regulations, without any type of cooperation in the commission of the

infringement among the different Rural Savings Banks that could determine different degrees of responsibility among the entities, as CAJAZAMORA claims.

CAJAZAMORA continues its reasoning by stating that “responsibility cannot be individualized without first objectifying the sanctioning reproach, and this cannot be projected in 26 procedures with their own dynamics, their own evidence...”. Abstract arguments continue to be made, such as objectifying the sanctioning reproach, regarding its own dynamics and “its own evidence,” when there have not even been allegations questioning the evidence of the facts, nor has there been a request for the admission of evidence in the procedure.

The fact that “a single investigation procedure” has been processed and that in this procedure no requirement has been directed against the entities responsible for the processing but rather against the processor (RSI) does not imply the “unitary factual determination,” as CAJAZAMORA argues. That the inspection actions were directed to require information from the processor does not determine that subsequently a single procedure must be initiated to clarify administrative responsibilities. It should be noted that Article 53, “Scope of the investigation activity,” of the LOPDGDD does not impose that these must necessarily be carried out concerning the data controller. Therefore, there is no obligation to investigate all the controllers that carry out the processing in question. Inspectors can obtain evidence by consulting and requiring information from the processor if they deem it appropriate.

4.3 Impact on the fundamental right to good administration

According to CAJAZAMORA, accumulation becomes an obligation in case the absence of it could harm the rights of the administered, particularly those recognized in Article 24 of the Constitution, thereby violating the right to good administration in accordance with Article 41 of the Charter of Fundamental Rights of the European Union.

In the previous allegations, the differences between the behaviors attributed to the Rural Savings Banks have been motivated, and it has been established that no type of defenselessness has been caused to CAJAZAMORA in the processing of the present procedure, having had access to all the documents in the file. In fact, CAJAZAMORA has not justified any type of defenselessness, nor does it point out any specific fact by which it has been caused defenselessness.

Finally, it should be reiterated that we are not dealing with the same facts, but rather with the same technical problem that caused a security incident of the system.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/58

computer-related of each of the responsible entities in relation to their processing of personal data (all of them legally and economically independent from each other), which has produced a series of personal data security breaches, not a single personal data security breach, but a personal data security breach in each of the Rural Savings Banks, which result in the alleged commission of a series of infringements by each of the different data controllers in relation to their processing of personal data and the rights and freedoms of their clients.

SECOND. THE NON-EXISTENCE OF GUILT IN THE PRESENT CASE

CAJAZAMORA has invoked various arguments to justify the absence of guilt in its conduct.

Firstly, it states that it is not involved in the facts attributed to it, since in the present case, the processing is carried out through a data processor; which, in turn, is the processor of the entities against which the proceedings are directed; and that the data protection regulations not only impose obligations related to compliance with the principle of confidentiality and the adoption of necessary security measures on the data controller but also, when the processing is carried out on behalf of the controller by a data processor, on the latter.

In this regard, it is worth recalling that the figure of the data processor responds to the need to address phenomena such as the outsourcing of services by companies and other entities, so that in those cases where the data controller entrusts a third party with the provision of a service that requires the processor to process personal data on its behalf, the processing or the operations of the processing are carried out by the processor, in the name and on behalf of the controller, as if it were the latter

carrying it out.

Therefore, the existence of a data processor depends on a decision made by the data controller, who may decide to carry out certain processing operations themselves or to contract all or part of the processing with a processor.

That is to say, the processor, in order to be one, does not have any own interest regarding the result of the processing subject to the assignment, without prejudice to the economic compensation it receives for the service rendered, which is what occurs in the present case. The processors have no own interest; they act on behalf of and in the name of the controller, following its orders and for its purposes, and this is what determines that they are processors from the outset.

This determines that the data controller is responsible for actions contrary to the GDPR carried out by its data processors, unless the latter had acted as true data controllers, deciding on the purposes and means of the processing, which has not occurred in the present case.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/58

Thus, the CJEU ruling of December 5, 2023, in case C-683/21, regarding the question of whether an administrative fine can be imposed under Article 83 of the GDPR on a data controller in relation to processing operations carried out by a processor, determines that,

“83 As for the second question regarding whether an administrative fine can be imposed under Article 83 of the GDPR on a data controller in relation to processing operations carried out by a processor, it should be recalled that, according to the definition in Article 4, point 8, of the GDPR, a processor is understood to be ‘the natural or legal person, public authority, service, or other body that processes personal data on behalf of the data controller.’

84 Given that, as indicated in paragraph 36 of this judgment, a data controller is responsible not only for all personal data processing that it carries out itself but also for processing carried out on its behalf, an administrative fine can be imposed on that controller under Article 83 of the GDPR in a situation where personal data is subject to unlawful processing and where it is not the controller, but a processor it has engaged, that has carried out the processing on its behalf.

85 However, the responsibility of the data controller for the behavior of a processor cannot extend to situations where the processor has processed personal data for its own purposes or where it has processed such data in a manner incompatible with the framework or modalities of processing as determined by the data controller or in a manner that cannot reasonably be considered to have been consented to by that controller. Indeed, in accordance with Article 28, paragraph 10, of the GDPR, the processor must, in that case, be considered responsible for the processing with respect to that processing.”

To the above, we must add the recent SAN of February 8, 2024, rec. 0002250/2021, regarding TELEFÓNICA MÓVILES ESPAÑA S.A.U, in which it is determined that,

“Well, the appellant company is the data controller, as it determines the purpose and means of the processing carried out for the purposes indicated in its Privacy Policy: ‘At Movistar, we process customer or user data for the provision of the service, as well as for other purposes that the customer allows or authorizes in the terms informed in this Privacy Policy or in the specific Conditions of each contracted Movistar Product or Service.’

While the companies ATENTO TELESERVICIOS ESPAÑA, S.A.U., CATHPONE-NET, S.L., and THADER TELECOMUNICACIONES S.L. are considered processors.

What has been stated derives from the contracts signed by the acting party with the aforementioned companies.

....

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Well, it has not been established that the aforementioned companies, as data processors for the plaintiff, have determined the purposes and means of the processing, nor have they used the clients' data for their own purposes, nor have they interacted with third parties unrelated to the structure and trade name of the appealing company, but rather have acted under the name of the plaintiff to fulfill its purposes, using its systems to carry out operations with the clients.

Therefore, it is not possible to invoke Article 28.10 of the GDPR for a presumed attribution of responsibility to the processors that would also imply the exoneration of the data controller, that is, of the company here appealing. On the other hand, according to the aforementioned contracts, there is a clause that passes on to them the possible sanctions that the plaintiff company may suffer for non-compliance with obligations regarding data protection.

On the other hand, the Guidelines 7/2020 of the EDPB on the concepts of "data controller" and "data processor" in the GDPR, version 2.0 adopted on July 7, 2021, determine that,

"30 Following the line of the fact-based approach, the word 'determine' means that the entity that actually exerts a decisive influence over the purposes and means of the processing is the controller. Generally, the processing contract establishes who is the determining party (the data controller) and who is the party that follows instructions (the data processor). Even when the data processor offers a service that is defined in advance in a specific way, it must present the data controller with a detailed description of the service, and the data controller must make the final decision on the approval of the manner in which the processing will be carried out and request any changes it deems necessary. Furthermore, the data processor cannot modify, at a later time, the essential elements of the processing without the approval of the controller.

...

39. The question is where to draw the line between the decisions reserved for the data controller and those that can be left to the discretion of the processor. It is evident that decisions regarding the purpose of the processing must always correspond to the controller.

40. As for the determination of the means, a distinction can be made between essential and non-essential means. Essential means are traditionally and inherently reserved for the data controller. These must be determined mandatorily by the data controller, although the determination of non-essential means can also be left to it. Essential means are those closely linked to the purpose and scope of the processing, such as the type of personal data processed ("What data will be processed?"), the duration of the processing ("How long will the data be processed?"), the categories of recipients ("Who will have access to the data?"), and the categories of data subjects ("To whom do the processed personal data belong?"). In addition to being related to the purpose of the processing, essential means are closely linked to the question of whether the processing is lawful, necessary, and

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es

36/58

provided. Non-essential means are related to more practical aspects of the processing itself, such as the choice of a particular type of hardware or software or the decision on the details of security measures, which may be left to the processor.

41. Although decisions regarding non-essential means may be left to the processor, the controller must still stipulate certain elements in the contract with the processor: for example, regarding the security requirement, all measures required under Article 32 of the GDPR may be mandated. The contract must also establish that the processor will assist the controller in ensuring compliance with, for example, the provisions of Article 32. In any case, the controller remains responsible for implementing appropriate technical and organizational measures to ensure and demonstrate that the processing is compliant with the Regulation (Article 24). To this end, the controller must take into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. For this reason, the controller must have complete information about the means used, as this will allow them to make an informed decision in this regard. In order for the controller to

demonstrate the legality of the processing, it is advisable to document, in the contract or another legally binding instrument between the controller and the processor, at least the necessary technical and organizational measures.

...

74. The GDPR establishes specific obligations that directly bind processors, as specified in section 1 of subsection II of these guidelines. It is possible to hold a processor accountable or sanction them when they fail to comply with such obligations or act outside or against the legal instructions of the controller.

...

80. Secondly, the processing must be carried out on behalf of a controller, but not under their direct authority or control. Acting "on behalf of" someone means serving the interests of another and refers to the legal concept of "delegation." In the case of data protection legislation, the role of the processor is to apply the instructions given by the controller, at least concerning the purposes of the processing and the essential elements of the means. The legitimacy of the processing under Article 6 and, if applicable, Article 9 of the Regulation derives from the activity of the controller, and the processor must only process the data following the instructions given by the controller. Nevertheless, as previously indicated, the instructions of the controller may leave some discretion regarding how best to serve their interests, allowing the processor to choose the most appropriate technical and organizational means.

81. Acting "on behalf of" someone also means that the processor cannot carry out the processing for their own purposes. As stipulated in Article 28, paragraph 10, the processor will violate the GDPR when they do not adhere to the instructions of the controller and begin to determine their own purposes and

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
37/58

means of processing. In these cases, the data processor shall be considered responsible in relation to such processing and may be sanctioned for failing to adhere to the instructions of the data controller."

Well, in the specific case under examination, and in light of the documentation in the file, it is noted that, for the provision of IT services, RSI and CAJAZAMORA have entered into an "Individualized and Specific Service Provision Contract" with each of the entities with RSI.

Additionally, it has also entered into the framework of the previous agreement the "Modification Agreement of the Data Protection Clause of the Service Provision Contracts between CAJAZAMORA and RSI," an agreement related to CAJAZAMORA, which was signed on 25/05/2018, by Mr. A.A.A., representing CAJAZAMORA (data controller).

In this regard, in this "Modification Agreement of the Data Protection Clause of the Service Provision Contracts between CAJAZAMORA and RSI," CAJAZAMORA is identified as the data controller and RSI is identified as the "Data Processor." The clause of Data Protection identifies RSI as the "Data Processor" and the Entities as the "Data Controllers."

Furthermore, in this "Modification Agreement of the Data Protection Clause of the Service Provision Contracts between CAJAZAMORA and RSI," this clause defines the processing activities that may be carried out by RSI on behalf of CAJAZAMORA, the type of information to be processed, and the categories of data subjects whose data may be processed.

It is also defined that the security measures that must be applied by RSI to ensure an adequate level of security according to the risk, as established in Article 32 of the GDPR, are those set out in Annex B of the "Modification Agreement of the Data Protection Clause of the Service Provision Contracts between CAJAZAMORA and RSI."

We must also highlight that it is stated in section 6 of the Agreement regarding "Liability" that, "If the Processor, or if applicable, the contractors, breach this Agreement or the current regulations by determining the purposes and means of processing, they will be considered responsible for the processing concerning such processing.

In the event that a supervisory authority sanctions the Data Controller as a direct consequence of the

Data Processor's failure to comply with the stipulations of this Agreement, the Processor shall indemnify the Data Controller as stipulated in the liability clause of the current framework contract between the parties.”

This implies, by contrast, and in accordance with the data protection regulations, the aforementioned judgments, and Guidelines 7/2020, that the data controller...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/58

The data controller is responsible for the actions carried out by its data processor unless the latter determines the purposes and means, resulting in the fact that this last issue has not been proven in the proceedings conducted.

Therefore, in accordance with the above, CAJAZAMORA and RSI are responsible for the processing that is carried out; they are the ones who have decided to entrust a data processor to carry it out on their behalf and for their account. They are the entity that has the true capacity to exercise control over the processing of personal data, determining which personal data will be processed on their behalf and for their account, the why and how the data should be processed, as they define the purpose of the personal data processing that their activity entails and choose the means they deem appropriate.

And in accordance with all of the above, in the specific case, CAJAZAMORA is responsible for the infringement of the GDPR even if it has occurred within its data processor. This is independent of the actions and responsibilities that third parties may have incurred, as the negligence or illegal actions of third parties do not exclude their own.

In this regard, in the very Agreement of Initiation, it is indicated in section 4 relating to the Obligations of the Data Controller that:

“It is the responsibility of the data controller:

- a) To provide the Data Processor with the necessary data for the provision of the service
- b) If legally required, to carry out a data protection impact assessment of the processing operations to be carried out by the Data Processor.
- c) To carry out the necessary prior consultations.
- d) To ensure, both prior to and throughout the processing, compliance with the GDPR by the Data Processor.
- e) To supervise the processing, including conducting inspections and audits.”

This is directly related to the principle of proactive responsibility of the data controller provided for in Article 5.2 of the GDPR, which establishes that “the data controller shall be responsible for compliance with the provisions of paragraph 1 and able to demonstrate it (“proactive responsibility”). This means that the controller must ensure the effective application of the principles of processing both at the time of determining the means of processing and during the processing itself, whether they carry out the processing of personal data directly or entrust a data processor to carry it out on their behalf (for the purposes of data protection legislation, it is the same), through the articulation of a series of technical and organizational measures of all kinds, which must be subject to periodic review and updating. This implies that the aforementioned controller is the one who assumes their own responsibility by directing, reviewing, and coordinating the processing, including that of the personnel and that of the data processor providing services to them.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/58

Opinion 3/2010, from the Article 29 Working Party (WP29) -WP 173- issued during the validity of the repealed Directive 95/46/EC, but whose provisions are applicable today, states that the “essence” of proactive responsibility is the obligation of the data controller to implement measures that, under normal circumstances, ensure that the data protection rules are complied with in the context of

processing operations and to have available documents that demonstrate to data subjects and supervisory authorities what measures have been adopted to achieve compliance with data protection rules.

For these purposes, consideration is given to the following Recital 74 of the GDPR:

“74. The responsibility of the data controller must be established for any processing of personal data carried out by themselves or on their behalf. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons.”

Completing the above and in development of Article 5.2 of the GDPR, Articles 24 and 25 of the same legal text should be cited, indicating the latter regarding "Data protection by design and by default" that the fundamental right to the protection of personal data is much more than mere technology, as its focus is on the risks to the rights and freedoms of data subjects arising from the processing of personal data,

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed...”

CAJAZAMORA seems to argue that the responsibility lies with the data processor with whom it entered into a contract and by virtue of which it was obliged to implement appropriate security measures according to the risk; however, it is worth recalling that the personal data breach occurred as a result of CAJAZAMORA's decision to switch from the Ruralvía Clásica application to a new NBE application for its clients to access electronic banking.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
40/58

subscribing for this purpose to the corresponding data processing agreement with RSI where CAJAZAMORA established the appropriate conditions.

And this is in addition to what this Agency has motivated in the preceding paragraphs regarding that CAJAZAMORA has determined the purposes and means of the processing, that it is responsible for the processing, that it is liable for the personal data breach in this case due to the processing actions carried out by its data processor on its behalf, and that it is subject to the obligations of the GDPR, especially concerning proactive responsibility.

This is the responsibility of CAJAZAMORA as it is the data controller and has the obligation to integrate and deploy data protection within all that constitutes its organization, in all its areas of action, whether affecting its employees or its data processors. It must be kept in mind that ultimately the determining purpose is to guarantee the protection of the data subject, as the focus is on the risks to the rights and freedoms of the data subjects arising from the processing of personal data.

Therefore, the data controller must carry out a risk analysis of the rights and freedoms of natural persons in data processing, implementing appropriate technical and organizational measures to apply the principles of data protection and integrate the necessary guarantees in the processing, in order to comply with the requirements of the GDPR, being able to demonstrate that the processing is in accordance with the provisions of the aforementioned regulation. And in light of the principle of

proactive responsibility (art. 5.2 GDPR), the data controller must be able to demonstrate that it has taken into account all the elements provided for in the GDPR.

Thus, all of this merely reflects a lack of diligence on the part of the investigated entity in ensuring adequate security relative to the risks of the data processing it carries out. In this regard, it should not be forgotten that the affected database contains personal data of thousands of clients, which constitutes large-scale processing, to which, in turn, access is made from web applications, that is, from the internet, with a very significant exposure surface, posing greater risks for the data subjects, which requires appropriate technical and organizational measures of all kinds, including security measures, adequate for this purpose and specifically aimed at ensuring that there is no unauthorized access to such personal data.

As has been demonstrated and argued throughout this sanctioning procedure, it is considered that appropriate security measures were not implemented in this case to ensure adequate security relative to the risk, even if there had not been a personal data breach, the security of the personal data of the clients, which determined in this case an unauthorized access to the personal data of CAJAZAMORA's clients. Therefore, responsibility is not being demanded solely as a consequence of a result caused by a cyberattack. It is another matter that has been highlighted in the event of a violation of the security of personal data.

It is much more; it is a failure to comply with the obligations imposed by the GDPR. Therefore, it is emphasized that the data controller must

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
41/58

establish, in its relationship with the data processor, clear modalities for such assistance and provide precise instructions to the data processor on how to comply with them appropriately and document it beforehand through a contract or in another (binding) agreement, and also subsequently during the validity of the same, and verify at all times during the execution of the contract its compliance in the manner established therein.

It suffices to bring to mind the content of the STS 1562/2020, which states the following:

"In this regard, the Judgment of the Supreme Court of June 5, 2004, which confirms, in cassation for Unification of Doctrine, that of this AN of October 16, 2003, echoing the arguments made by this Chamber, refers to the differentiation of two responsible parties based on whether the decision-making power is directed at the file or at the data processing itself. Thus, the data controller is the one who decides the creation of the file and its application, as well as its purpose, content, and use, that is, who has decision-making capacity over all the data recorded in that file. The data processor, however, is the subject to whom the decisions regarding the specific activities of a particular data processing operation can be attributed, that is, regarding a specific application. This would pertain to all those cases in which the decision-making power must be differentiated from the material execution of the activity that comprises the processing. With this, as also argued by the STS of April 26, 2005 (cassation for unification of doctrine 217/2004), the Spanish legislator aims to adapt to the requirements of Directive 95/46/EC, which seeks to provide a legal response to the phenomenon, which is increasingly frequent, of the so-called outsourcing of IT services, where multiple operators act, many of them insolvent, created with the aim of seeking impunity or irresponsibility for those who follow in the subsequent links of the chain. Currently, the new Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data (which repeals Directive 95/46/EC, and is directly applicable from May 25, 2018) also distinguishes between the figures of the controller and the processor. The former is defined in paragraph 7) of Article 4 as "a natural or legal person (...) who determines the purposes and means of the processing." And the processor in paragraph 8) of the same Article 4 as one who "processes personal data on behalf of the data controller."

This in relation to Articles 24 and 28 of the same European Data Protection Regulation. The data controller and processor are undoubtedly also responsible for violations regarding data protection, in

this new regulatory framework, in accordance with the provisions of Article 82.2 of the aforementioned Regulation (EU) 2016/679, which states: Any controller participating in the processing operation shall be liable for the damages caused in the event that such operation does not comply with the provisions of this Regulation. A processor shall only be liable for the damages caused by the processing when it has not complied with the obligations of this Regulation specifically directed at processors or has acted outside or against the legal instructions of the controller. It follows from all of the above that the concurrence, in the present case, of a processor of

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
42/58

The treatment ZZZZ does not exempt the entity XXXX, now the appellant, from liability, despite the strength of the clauses contained in the contract and its annex signed by both companies (proven facts 9 and 10), as the personal data processed was for the purpose of carrying out an advertising campaign regarding car and motorcycle insurance marketed by XXXX, ultimately benefiting said XXXX, being that entity the one that ultimately determines the purposes and means of the repeated data processing, therefore it cannot be exempted from liability...

The Supreme Court continues, regarding the possible exemption of liability alleged in relation to what was signed in the "data processing agreement," as follows:

"The sanctioned conduct of obstruction or impediment by XXXX of its client's exercise of the right to object to the processing of their data is manifested in that said company did not adopt any kind of measure or precaution to prevent the sending of advertising to its client's email addresses by those companies to which it entrusted the execution of the advertising campaigns.

The adoption of the necessary measures or precautions to ensure the effectiveness of the right to object to the processing of their data by XXXX, as the data controller, remains in effect even if the advertising campaigns are not carried out based on data from its own files, but rather with databases from other companies contracted by XXXX, and in this case, it was established that the appellant did not communicate to the companies with which it contracted the provision of advertising services the complainant's objection to receiving advertising from the Mutual, nor did it ultimately adopt any provision to ensure the exclusion of its client from the advertising mailings contracted with third parties."

Regarding the application of the principle of culpability in the field of sanctioning law regulated by the GDPR, the investigated entity brings up the doctrine established by the CJEU ruling of December 5, 2023 (case C-807/21, Deutsche Wohnen SE and Staatsanwaltschaft Berlin).

Well then, it is pertinent to ask what the parameters of due diligence that the investigated entity should have observed in relation to the examined conduct are. The answer is that the diligence it should have observed is that which was necessary to fulfill the obligations imposed by Articles 5.2, 24, and 25 of the GDPR, in light of the doctrine of the National Court and the jurisprudence of the Supreme Court. The SAN ruling of October 17, 2007 (rec. 63/2006) is fully applicable to the case, which, after referring to the fact that entities whose activities involve continuous processing of data from clients and third parties must observe an adequate level of diligence, states:

"(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, it must be..."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
43/58

"particular attention must be paid to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and

abundant handling of personal data, it is essential to insist on rigor and exquisite care in adhering to the legal provisions in this regard."

Furthermore, the National Court in matters of personal data protection has declared that "simple negligence or failure to comply with the duties imposed by law on those responsible for files or data processing is sufficient to require extreme diligence..." (Judgment of the National Court of June 29, 2001).

Regarding the allegation that the breach of personal data occurred within the framework of the data processing for which RSI was responsible, to the extent of carrying out the investigative actions exclusively with that entity, it should be noted that the preliminary investigative actions are precisely carried out to clarify the facts and circumstances of what happened, gathering more information in order to determine whether or not there is a possible infringement of the data protection regulations. In this sense, the initiation of preliminary investigations and their execution, which is the authority of the AEPD, does not prejudice anything, but rather allows for the determination of the facts that occurred and the collection of necessary information wherever it may be found to ascertain whether there are indications of an infringement or not. Even after such an investigation, it may be that the proceedings are archived because, based on the information gathered, it is understood that there are no indications of infringement. This has not happened in the present case.

Consequently, the allegations must be dismissed since the investigated entity has infringed the obligations imposed by the GDPR as the controller of the processing carried out in its name and on its behalf, in relation to the responsibilities required of every data controller by Article 24 of the GDPR. Therefore, the allegations must be dismissed, emphasizing that the arguments presented do not undermine the essential content of the infringement declared to have been committed nor do they constitute sufficient justification or exculpation.

THIRD. ON THE IMPACT ON THE PRINCIPLES OF SANCTIONING LAW DERIVED FROM THE INTERPRETATION MADE BY THE AEPD

CAJAZAMORA considers that it has not committed any infringement of the Data Protection regulations, much less the simultaneous infringement of Articles 5.1 f) and 32 of the GDPR, as the triple identity of subject, fact, and protected legal interest coincides; there is no doubt that in this case the principle of non bis in idem should be applied, with the imposition of a sanction only for Article 5.1.f) since it is more serious than either of the two infringements attributed.

And in the event that the AEPD finds a violation, it should subsidiarily recognize a medial concurrence as one of the infringements is subsumed and embedded in the other, according to what is provided in Article 29.5 of the LRJSP, "When the commission of one infringement necessarily derives from the commission of another or others, it shall..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/58

"only the sanction corresponding to the most serious infringement committed shall be imposed."

"1. Violation of the principle of non bis in idem in the application of Articles 5.1 f) and 32 of the GDPR"

In this regard, and in relation to this allegation made by CAJA XXX against the initiation agreement, it should be noted that since the filing of the initially charged infringement under Article 32 of the GDPR has been proposed, it is no longer necessary to respond to these allegations, as the charge under Article 5.1 f) of the GDPR no longer coincides with Article 32 of the GDPR.

FOURTH. ON THE ALLEGED VIOLATION OF ARTICLE 32.1 OF THE GDPR.

CAJAZAMORA has stated that the AEPD considers the alleged violation of Article 32 of the GDPR to be "evidenced," meaning it considers the alleged insufficiency of the security measures adopted to be evident due to the occurrence of the personal data breach, making exclusive reference to the report on the breach contained in the administrative file, while disregarding all the measures adopted as well as the audit carried out, and that there is a misinterpretation of what occurred in the RSI systems, indicating that modifications had been introduced in the SSO process for access to the NBE after the aforementioned audit.

Well, as indicated, upon reviewing the allegations made by the respondent party, and in consideration of them, reviewing the documentation in the administrative file and that provided by the respondent party, it is evident that all the technical and organizational security measures whose absence has been proven have had a direct impact on the personal data breach, without there being a violation, in this specific case, of Article 32 of the GDPR, as the absence of other independent technical and organizational security measures unrelated to the personal data breach has not been substantiated. Regarding the sufficiency of the security measures, in relation to the non-compliance with Article 5.1 f) of the GDPR, we refer to what has already been indicated in the legal basis IV of this proposal for resolution, which explains and details why they were neither sufficient nor appropriate.

Furthermore, we will indicate that it is true that it is recorded that both prior to and subsequent to the security incident, the investigated entity conducted audits and reviews by third-party specialists aimed at detecting vulnerabilities related to the security of the information systems; but it is also true that despite the existence of such investigations, controls, and verifications, they were unable to locate and reveal the existing vulnerabilities, as evidenced in the proven facts.

CAJAZAMORA claims that RSI has various security certifications, referenced in the third proven fact of this proposal for resolution.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/58

Article 28 of the GDPR, Processor, in its paragraph 5, establishes that:

“5. The adherence of the processor to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may be used as an element to demonstrate the existence of sufficient guarantees referred to in paragraphs 1 and 4 of this article.”

In this regard, to demonstrate that processors offer the suitability and guarantees required by the GDPR, adherence to a certification mechanism may be used as an additional element to establish the existence of sufficient guarantees to implement appropriate technical and organizational measures to protect personal data.

This is because, in addition to a processor being certified in data protection, this certification does not absolutely prove that the sufficient guarantees in relation, in this case, to the provision of Article 28.1 of the GDPR, have been implemented and are effectively operating throughout the entire processing cycle and during the time that the processing is taking place.

In the area of data protection, this type of instrument is a mechanism of voluntary compliance in which specific rules are established with the aim of contributing to the correct application of the GDPR and the LOPDPGDD.

According to the GDPR, the data controller must adopt appropriate measures, including the selection of processors, in such a way as to guarantee and be in a position to demonstrate that the processing is carried out in accordance with the GDPR (principle of active accountability).

It is true that the certifications that the processor RSI seems to have are mentioned in the processing agreement; however, let us note that all the certifications listed in the third proven fact are not certifications as provided for in either Article 28 or Article 42 of the GDPR; they are not data protection certifications, but rather certifications of information security or related to other obligations that must be fulfilled by the controller or the processor based on other regulations different from data protection.

Thus, in the “Amendment Agreement to the Data Protection Clause of the Service Provision Contracts,” signed between CAJAZAMORA and RSI, in its “Annex B - Security Measures to the Amendment Agreement to the Data Protection Clause of the Service Provision Contracts,” it is indicated that RSI holds the following certifications:

(...)

In addition to the fact that its mention in the processing agreement is not accompanied by the certification itself for the purposes of verifying that it has indeed been certified and to see exactly what it is certified for, when it was certified, and if at

46/58

At the time of the personal data breach, the certification was still valid (since certifications have a validity period); this certification does not pertain to data protection.

In this regard, the report of the Legal Cabinet 170/2018 of the AEPD establishes the difference between information security and the protection of personal data. Thus, it is indicated that, "Prior to analyzing the specific issue raised in the consultation, this Legal Cabinet finds it appropriate to make a prior reference to the substantive and jurisdictional differentiation that exists between the field of information security and that of the protection of personal data.

Regarding information security, it encompasses the set of techniques and measures aimed at ensuring the confidentiality, integrity, and availability of information and data important to any organization, regardless of their format.

(...)

On the contrary, the protection of personal data of natural persons is configured as a true fundamental right that finds its basis in Article 18.4 of the Spanish Constitution, according to which "the law will limit the use of computing to guarantee the honor and personal and family privacy of citizens and the full exercise of their rights." This has been recognized by our Constitutional Court, highlighting in Judgment 94/1998, of May 4, that the aforementioned Article 18.4 "not only entails a specific instrument for the protection of citizens' rights against the tortious use of computing technology, but also enshrines an autonomous fundamental right to control the flow of information concerning each person - to 'privacy' according to the neologism stated in the Explanatory Memorandum of the LORTAD - whether or not it belongs to the strictest realm of intimacy, in order to preserve the full exercise of their rights."

This is reflected in the Preamble of the Organic Law Project on Personal Data Protection and Guarantee of Digital Rights, which is transcribed below for its clarity:

"The protection of natural persons in relation to the processing of personal data is a fundamental right protected by Article 18.4 of the Spanish Constitution. In this way, our Constitution was a pioneer in recognizing the fundamental right to the protection of personal data when it stipulated that 'the law will limit the use of computing to guarantee the honor and personal and family privacy of citizens and the full exercise of their rights.' It echoed the work developed since the late 1960s in the Council of Europe and the few legal provisions adopted in countries around us.

The Constitutional Court pointed out in its Judgment 94/1998, of May 4, that we are faced with a fundamental right to data protection that guarantees the individual control over their data, any personal data, and over its use and destination, to prevent the illicit trafficking of the same or harm to the dignity and rights of those affected; thus, the right to data protection is configured as a citizen's ability to oppose that

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/58

certain personal data be used for purposes other than those that justified its acquisition. For its part, in Judgment 292/2000, of November 30, it considers this as an autonomous and independent right that consists of a power of disposition and control over personal data, enabling the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which data this third party may collect, and also allowing the individual to know who holds that personal data and for what purpose, being able to oppose such possession or use.

At the legislative level, the specification and development of the fundamental right to the protection of individuals in relation to the processing of personal data took place in its origins through the approval of Organic Law 5/1992, of October 29, regulating the automated processing of personal data, known as LORTAD. Organic Law 5/1992 was replaced by Organic Law 15/1999, of December 5, on the protection of personal data, in order to transpose into our law Directive 95/46/EC of the European Parliament and of the Council, of October 24, 1995, regarding the protection of individuals in relation to the processing of personal data and the free movement of such data. This organic law represented a second milestone in the evolution of the regulation of the fundamental right to data protection in Spain

and was complemented by an increasingly abundant jurisprudence from the contentious-administrative jurisdictional bodies.

On the other hand, it is also included in Article 8 of the Charter of Fundamental Rights of the European Union and in Article 16.1 of the Treaty on the Functioning of the European Union. Previously, at the European level, the aforementioned Directive 95/46/EC had been adopted, whose purpose was to ensure that the guarantee of the right to the protection of personal data did not constitute an obstacle to the free movement of data within the Union, thus establishing a common space of guarantee of the right that, at the same time, ensured that in the case of international data transfer, its processing in the destination country was protected by safeguards adequate to those provided for in the directive itself. And in this same sense, Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the protection of individuals in relation to the processing of their personal data and the free movement of such data, which repeals Directive 95/46/EC (General Data Protection Regulation, GDPR), states that its purpose is “to protect the fundamental rights and freedoms of natural persons and, in particular, their right to the protection of personal data” (Article 1.2), highlighting in its Recital 1 that “the protection of individuals in relation to the processing of personal data is a fundamental right” and in its Recital 10 that “to ensure a consistent and high level of protection for individuals and to eliminate obstacles to the free movement of personal data within the Union, the level of protection of the rights and freedoms of individuals with regard to the processing of such data must be equivalent in all Member States. It must be ensured throughout the Union that the application of the rules for the protection of the fundamental rights and freedoms of individuals in relation to the processing of personal data is consistent and homogeneous.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/58

Consequently, the right to the protection of personal data of individuals is a fundamental right and, therefore, situated at the highest level of legal protection, which is currently directly regulated by community legislation, with the aforementioned GDPR establishing a set of principles, rights, obligations, and an organizational structure aimed at guaranteeing this fundamental right. Among these, information security appears as an additional obligation for data controllers and processors, who must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which will include, among other factors, “the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services” and “the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident” (Article 32.2. b) and c) of the GDPR).

Therefore, there is no doubt that the guarantee of the security of personal data acquires special significance regarding its protection, but without being limited exclusively to the realm of the security of that information, as the protection of personal data has a much broader scope that encompasses, as we mentioned, a set of principles, rights, and obligations that is much wider.

This issue is substantial since the certification mentioned in the service contract does not serve as an element to “demonstrate the existence of the sufficient guarantees referred to in paragraphs 1 and 4” of Article 28 of the GDPR, as it does not pertain to data protection. The difference in approach between mere information security and data protection is extremely important, as while the former's approach focuses exclusively on the security of information, the risk-based approach of the GDPR (which is much broader as it focuses on the risks to the rights and freedoms of data subjects arising from the processing of personal data) is centered on individuals, with security being an additional obligation within the GDPR to achieve the protection of individuals in the terms of recitals, notably 1 and 10, as well as in accordance with the provisions of Article 1 of the GDPR.

Within the management of GDPR compliance lies risk management, on which information security pivots, and not the other way around.

(...)

CAJAZAMORA claims that the security measures initially implemented by RSI are outlined in the

service contract signed with RSI and that the attackers could have legitimate credentials for access and that the attack is not due to the weakness of the implemented systems.

As a preliminary matter, we must refer to the proven facts and the description of the personal data breach to understand how and why the personal data breach occurred.

Regarding the security measures included in the "Amendment Agreement of the Data Protection Clause of the Contracts of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/58

"provision of services", when referring to security measures, there is a reference to those listed in Annex B - Security Measures to the Agreement modifying the data protection clause of the service provision contracts.

Well, from a detailed examination of the citation of the same, since we are unaware of the description of the specific measures implemented, we can again verify that they are measures that refer generally to information security and not to data protection (...). A policy is a central and guiding instrument of an organization in which the responsible party addresses its objectives and establishes procedures, resources, and mechanisms to carry it out, requiring subsequent detailed development. It is not the same to address mere information security as it is to address the protection of a fundamental right such as data protection, considering the focus and purpose of each of them.

Moreover, the fact that a list of measures appears in a service contract (specifically, information security measures in this case) does not imply that they guarantee appropriate security as determined by Article 5.1.f) of the GDPR, because one must consider the focus on the protection of the rights and freedoms of the data subjects, and the measures implemented do not necessarily serve to fulfill such an objective if they have not been designed and implemented from the perspective required by the GDPR.

FIFTH. ON THE ALLEGED VIOLATION OF ARTICLE 5.1.f) OF THE GDPR.

CAJAZAMORA considers the contradiction in which the Initiation Agreement incurs by stating that "the identification of a personal data breach does not imply the direct imposition of a sanction by this Agency, as it is necessary to analyze the diligence of controllers and processors and the security measures applied," when it subsequently understands that Article 5.1.f) has been violated as a consequence of the mere fact that the breach has occurred.

On this particular matter, we refer to the legal basis IV explaining the concurrence of the infringement of Article 5.1.f) of the GDPR in this specific case, where it is detailed that the infringement has not been committed merely due to the result of loss of confidentiality, even though it is a result-based infringement.

The Judgment of the Constitutional Court (STC) 292/2000, in its analysis of the "content" of the fundamental right to data protection, refers to the power of disposition and control that belongs to the data subject over the possible use or uses of their data by a third party. The seventh legal basis states: "[...] it turns out that the content of the fundamental right to data protection consists of a power of disposition and control over personal data that enables the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which this third party may collect, and that also allows the individual to know who possesses that personal data and for what purpose, being able to oppose such possession or use. These powers of disposition and control over the data

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/58

personal data, which constitute part of the content of the fundamental right to data protection, is legally specified in the ability to consent to the collection, obtaining, and access to personal data, its subsequent storage, as well as its possible use or uses by a third party, whether the State or a private

individual."

The obligation of confidentiality imposed on the data controller by Article 5.1(f) of the GDPR is an obligation of result, such that for the provision to be considered violated, the confidentiality of the data must be breached.

As specified in the Supreme Court ruling of 15/02/2022 (rec. of cassation 7359/2020):

"The obligation to adopt the necessary measures to ensure the security of personal data cannot be considered an obligation of result, which implies that if a leak of personal data to a third party occurs, there is liability regardless of the measures adopted and the activity carried out by the data controller or processor.

In obligations of result, there is a commitment to achieve a specific objective, ensuring the achievement or proposed result, in this case, to guarantee the security of personal data and the non-existence of leaks or security breaches (...).

It should be noted that the data controller incurs in contradiction when, on the one hand, it considers that there has been no violation of data protection regulations and believes that everything should be redirected to the filing of the case, while on the other hand, it confirms and indicates that it is evidenced in the file "that the attacker could access the data, but in no case alter it, ..."; (...)".

(...)

Regarding the allegations reiterated by the respondent that the violations attributed concerning Article 5.1(f) and 32 of the GDPR are identical since we are faced with the same fact subject to double imputation, we refer to what has already been indicated in the previous legal grounds regarding the proposed filing of the violation of Article 32 of the GDPR.

In light of the above, it is established that CAJAZAMORA has violated the principle of confidentiality and integrity of data, a principle enshrined in Article 5.1(f) of the GDPR, an infringement classified under Article 83.5(a) of the GDPR.

SIXTH. ON THE ALLEGED VIOLATION OF ARTICLE 33 OF THE GDPR

Regarding the allegations made by the claimant concerning the imputation of Article 33 of the GDPR, a response is no longer necessary, as, as stated in the proven facts and in the preceding legal grounds, the filing of the initially attributed violation is proposed in light of the specific circumstances of the case previously expressed.

SEVENTH. VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY IN THE DETERMINATION OF SANCTIONS.

CAJAZAMORA has alleged that if it is considered that there has been a violation of data protection regulations, particular consideration should be given in determining the sanction that may be imposed by applying the principle of proportionality.

It should be noted that Article 83.1 of the GDPR states that "Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this article for the violations of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive."

Fines, therefore, as deduced from the invoked provision, must be effective, proportionate, and dissuasive to achieve the intended purpose of the GDPR.

It is true that for this system to function with all its guarantees, it is necessary for several elements to be deployed fully and completely. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case as permitted by the GDPR itself - would undermine the effectiveness of the system, losing its meaning, its teleological purpose, the legislator's intent, resulting in fines imposed for different violations ceasing to be effective, proportionate, and dissuasive. And in this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms.

Regarding the principle of proportionality of sanctions, the National Court in numerous rulings has stated that the principle of proportionality cannot be exempt from judicial review, as the margin of

appreciation granted to the Administration in imposing sanctions within the legally established limits must be developed by weighing, in any case, the concurrent circumstances, in order to achieve the necessary and due proportion between the alleged facts and the responsibility required, given that any sanction must be determined in congruence with the severity of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the fact. Thus, proportionality constitutes a normative principle that is imposed on the Administration and that reduces the scope of its sanctioning powers.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
52/58

Well, in accordance with the circumstances present in this case, which have been meticulously and appropriately evaluated, this resolution does not violate the principle of proportionality in the determination of the imposed sanctions, resulting in a balanced and proportionate response to the severity of the infringement committed, the importance of the facts, as well as the circumstances taken into account to gradate the sanction, without any reasons being appreciated that would further justify the reduction made, especially considering the amount to which such sanctions may ascend in accordance with Article 83.5 of the GDPR, which provides for an infringement of Article 6.1 of the GDPR, “with administrative fines of up to €20,000,000 or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount.”

In the present case, the entity under investigation is a large company within its sector of activity; according to the proven fact twenty-first, its turnover (gross margin) during the year 2022 amounted to €25,411,000, resulting in the fine imposed for the infringement of Article 5.1.f) of the GDPR amounting to €15,000, which would be in the lower bracket of the possible administrative fine that could be imposed on the data controller and far from the maximum of 4% of the total annual global turnover of the previous financial year considering the turnover.

- CAJAZAMORA considers regarding the circumstance derived from the nature, severity, and duration of the infringement that the mere reference to the provision subject to the infringement is taken as an aggravating factor.

However, such an argument cannot be accepted as inconsistent; in fact, what is being highlighted is that the infringement of Article 5.1.f) affects one of the basic principles on which the regulations on the protection of personal data are based, confidentiality, and this violation is heightened and aggravated by the number of individuals affected by the incident, the damages and losses caused (irreversible loss of power and control over personal data by clients) and its duration, since (...).

- CAJAZAMORA considers regarding the intentionality or negligence in the infringement that the absence of diligence in its actions is due exclusively to its condition as a financial entity and, in purity, the aforementioned statement is surprising.

Taking into account that in CAJAZAMORA's conduct the element of culpability is present, which is essential to demand sanctioning responsibility, in this case, it is also specified in a very serious lack of diligence in complying with the principle of confidentiality of personal data as has been demonstrated throughout the procedure.

RSI has pointed out that:
(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
53/58

The number of affected clients by the breach is 4 users; all of them were informed of the security incident that occurred.

Furthermore, the lack of diligence demonstrated in the infringing conduct for which it is held

responsible must be classified as very serious; CAJAZAMORA is obliged under Article 5.2 of the GDPR to carry out the appropriate activity to comply with the principles of data protection, particularly the principle of confidentiality, and to be in a position to demonstrate its compliance.

- CAJAZAMORA considers that taking its banking activity into account as an aggravating factor is a type of objective aggravation; firstly, it is not a matter related to the specific activity carried out by a particular entity, but rather the aggravating factor provided for in Article 76.2.b) of the LOPDGDD operates when the infringer's activity is linked to the processing of personal data, and it is obvious that, in relation to the present data controller, its activity, in this specific banking case, is clearly linked, directly, to multiple processing of personal data affecting thousands of clients.

In this regard, the National Court has considered it correct to appreciate the aggravating factor provided for in Article 76.2.b) of the LOPDGDD whenever the aforementioned link exists, and it has considered this in numerous rulings, including the ruling dated 04/07/2024, (rec. 382/2022) which states regarding the cited circumstance that:

“As well, the aggravating factor of the continued nature of the infringement, as set out in Article 76.2.a) of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, can also be appreciated, referring to it when we analyze the application of the GDPR to the infringement at hand. As well as the appreciation of the link between the infringer's activity and the processing of personal data (Article 72.2.b) of Organic Law 3/2018, of December 5), due to the fact that the activity of the appellant is linked to the processing of data from both clients and third parties; this cited link is well-known since the entity, due to its activity, is in permanent contact with clients and third parties handling a large volume of data, which imposes a greater duty of diligence” (the underlining is ours).

Finally, CAJAZAMORA considers that the AEPD, in modulating its responsibility, has not taken into account elements to mitigate it, such as evidentiary elements that demonstrate compliance with the highest standards in security matters, nor the fact of subjecting the measures adopted to a system of periodic auditing or that RSI resolved the vulnerability that constituted the security breach; it is sufficient to refute what has been stated by referring to the content of the proven facts and regarding the last issue raised, to refer to what the data processor itself indicates in its document notifying the personal data breach, dated 14/12/2022, and the document of 10/01/2023 transferring the final report, in which it responds to the following questions:

- Could the breach have been avoided by adopting any additional security measures?

Yes

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

54/58

- Did the incident occur due to any failure, deficiency, or non-compliance with implemented security measures?

Yes

And regarding the actions taken after the incident:

- Have you adapted/improved your security procedures and policies?

No

Therefore, the allegation made regarding the violation of the principle of proportionality cannot be accepted.

In view of the above, the following
PROPOSAL FOR RESOLUTION

That the Director of the Spanish Agency for the Protection of Data sanctions CAJA RURAL DE ZAMORA with NIF (...), for the infringement of Article 5.1.f) of the GDPR, classified in Article 83.5.a) of the GDPR, with a fine of €15,000 (fifteen thousand euros).

That the Director of the Spanish Agency for the Protection of Data archives CAJA RURAL DE ZAMORA with NIF (...), for the infringement of Article 32.1 of the GDPR, classified in Article 83.4.a) of

the GDPR.

That the Director of the Spanish Agency for the Protection of Data archives CAJA RURAL DE ZAMORA with NIF (...), for the infringement of Article 33.1 of the GDPR, classified in Article 83.4.a) of the GDPR.

Likewise, in accordance with the provisions of Article 85.2 of the LPACAP, it is informed that it may, at any time prior to the resolution of this procedure, make the voluntary payment of the proposed sanction, which will entail a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at €12,000 (twelve thousand euros) and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures. The effectiveness of this reduction will be conditioned on the withdrawal or renunciation of any action or appeal in the administrative route against the sanction.

In the event that it opts to proceed with the voluntary payment of the amount specified above, in accordance with the provisions of the aforementioned Article 85.2, it must make it effective by depositing it into the restricted account No. IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for the Protection of Data at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason, for voluntary payment, for the reduction of the amount of the sanction. Likewise, it must send the proof of payment to the General Inspection Subdirectorato to proceed with closing the file.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
55/58

By virtue of this, you are notified of the above, and the procedure is made available to you so that within TEN DAYS you may allege whatever you consider in your defense and present the documents and information you deem pertinent, in accordance with Article 89.2 of the LPACAP.

D.D.D.

INSPECTOR/INSTRUCTOR

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

56/58

ANNEX

Index of file EXP202400080

(...)

SECOND: On December 20, 2024, the respondent has proceeded to pay the fine in the amount of 12,000.00 euros, making use of the reduction provided in the resolution proposal transcribed above.

THIRD: The payment made entails the waiver of any action or appeal in the administrative route against the sanction, in relation to the facts referred to in the resolution proposal.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict

them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

- "1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.
2. When the sanction is solely pecuniary or when it is possible to impose a pecuniary sanction and another non-pecuniary sanction but the impropriety of the latter has been justified, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.
3. In both cases, when the sanction is solely pecuniary, the competent body to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which may be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure and their effectiveness will be conditioned on the withdrawal or waiver of any action or appeal in the administrative route against the sanction. The percentage of reduction provided in this section may be increased by regulation."

III

Voluntary payment

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified resolution proposal allowed for the voluntary payment of the proposed sanction, which would entail a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at 12,000.00 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Following the aforementioned resolution proposal, and before a resolution was issued by this authority, the respondent, on December 20, 2024, proceeded to make the voluntary payment, availing themselves of the 20% reduction and waiving any action or appeal in the administrative route.

It should be noted that, in accordance with the provisions of the LPACAP, as well as the jurisprudence of the high court in this matter, the exercise of voluntary payment by the alleged responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and those arising from it.

Therefore, in accordance with the applicable legislation and assessed the criteria for the graduation of the sanctions whose existence has been proven, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the resolution proposal transcribed in this resolution.

The sum of the aforementioned amounts results in a total of 15,000.00 euros.

After the respondent has proceeded with the prompt payment, although without acknowledgment of responsibility, it is proceeded, by virtue of Article 85 of the LPACAP,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

58/58

to the reduction of 20% of the total mentioned, which amounts to the definitive sum of 12,000.00 euros.

SECOND: DECLARE the termination of the procedure EXP202400080, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: NOTIFY this resolution to CAJA RURAL DE ZAMORA COOPERATIVA DE CRÉDITO.

FOURTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment on the withdrawal or renunciation of any action or administrative appeal by the present authority, the express renunciation stated by the claimed party is accepted, and consequently, the filing of an optional appeal for reconsideration against this resolution is not admissible, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since no administrative appeal is admissible due to the express renunciation, this resolution will be fully enforceable from the notification of the same.

However, in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative route may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with the documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to the vacancy of the Presidency and Deputy Presidency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es